

2.5A External Transmission Data Protection

Control Type: Advisory	Applies to architecture:	A1	A2	A3	A4	B
Control Definition Control Objective: Protect the confidentiality of Swift-related sensitive data transmitted or stored outside of the secure zone as part of operational processes. In-scope components: - Swift-related secure zone components, including the Alliance Connect Virtual on Premises VPN, deployed on-premises or, when allowed, remote (hosted or operated by a third party, or both), sensitive data (such as back-ups, business transaction details, and credentials) Risk Drivers: - compromise of trusted back-up data - loss of sensitive data confidentiality						
Implementation Guidance Control Statement: Sensitive Swift-related data that leaves the secure zone as a result of operating system or application back-ups for recovery purposes, business transaction data replication for archiving, or extraction for offline processing is protected when stored outside of a secure zone and is encrypted while in transit to the first storage location. Control Context: While 2.4 covers the back-office application flows with the Swift-related components, this control covers the underlying Swift-related data that resides in the cloud or is exported from the secure zone and manipulated as per operational activities (such as back-ups or manual/automated data extraction/copies). Operating system or applications back-ups and the replication of business transaction data can provide useful information to prepare fraudulent transactions. The initial transfer, handling, and storage outside of secure zones (when, for example, using the SAN/NAS²⁷ technology) must therefore be secured to prevent unauthorised access. Flow or data encryption are usual means to protect such data in transit. Back-up encryption, encryption of data at rest, or appropriate authorisation and access controls are usual means to protect stored data. Offline processing covers, for example, processing performed for support activities, additional analysis, or business intelligence activities. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - Replicated (including back-ups) or extracted Swift-related sensitive data (business transaction data that reveals details such as involved debtors, creditors, accounts, amounts, trade information), passwords, and other authenticators are as follows: - Protected from unauthorised access when stored outside of the Swift or customer secure zone or another secure zone that has similar controls as the Swift or customer secure zone. Such replicated or extracted data is also ideally encrypted when stored outside of a secure zone (this can be achieved either at the data, file, application, or system level).						

²⁷ Storage Area Network / Network Attached Storage both providing network storage solutions²⁸ Advanced Encryption Standard

- Encrypted when in transit between secure zones (for example, between data centres or between on-premises and remote, such as in the cloud, environments) or transferred outside of a secure zone either on-premises or remote. Encryption can be applied on the data or at the network/communication/transport layer.
- When relying on a remote virtualisation or cloud platform (that is hosted or operated by a third party, or both), it is recommended to ensure the encryption of the data. This can be obtained at the subscription level or at the storage level, expected to be offered by the third party to provide a guarantee in regard to access to stored data.
- Encryption protocols or mechanisms use a current, commonly accepted cryptographic algorithm (for example, AES²⁸ or ECDHE²⁹) with key lengths in line with current best practices. For more information about cryptographic algorithms that currently support secure protocols, see the [Knowledge Base article 5021566](#).
- Encryption mechanisms comply with applicable laws and regulations³⁰.
- If the cryptography protecting Swift-related sensitive data has been compromised, then a process should be established to apply new cryptography and secure or destroy any compromised copies of the data.
- Credentials and private or bilateral (cryptographic) keys used, and usually stored, by applications to secure the data transmission are protected. This can be achieved through a large spectrum of methods, from definition and usage of secure coding guidelines to the use of specific solutions such as KMS, secured based on the user's risk management.

Note: It is expected that back-ups kept for business or system recovery are maintained in a secure zone that has similar controls to the Swift or customer secure zone.

²⁸ Advanced Encryption Standard

²⁹ Elliptic Curve Diffie-Hellman Ephemeral

³⁰ Such as those identified by Global Partner Digital (<https://www.gp-digital.org/world-map-of-encryption/>)